ביקורת תלויות וסודות (עברית)

מסמך	ביקורת תלויות וסודות (עברית)
נתיב המקור	docs/security/DEPENDENCY_AND_SECRETS_AUDIT_HE.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

Source: docs/security/DEPENDENCY_AND_SECRETS_AUDIT.md @ 544b975b

> תרגום של `docs/security/DEPENDENCY_AND_SECRETS_AUDIT.md`; המקור באנגלית קובע במקרה של סתירה.
>
> הערת תרגום: הסריקה האחרונה הרשומה כאן היא מ-22.09.2026 בגרסה 0.1.81; הפיתוח המשיך מאז עד 0.1.128 (ראו `smplwise_vms/CHANGELOG.md`) בלי שנרשמה כאן סריקה חוזרת חדשה יותר. המסמך מתורגם כפי שהוא במקור, בלי לעדכן תאריכים או תוצאות.

ביקורת תלויות, רישוי וסודות (T005)

תאריך: 16.09.2026 (ביקורת ראשונה ב-0.1.21) · הרצה חוזרת 22.09.2026 ב-0.1.81 (§2, §6) · היקף: מאגר ה-add-on (backend, אינטגרציה, frontend, תמונה) · שיטה: מלאי מקובצי ה-lock, הרצות `pip-audit` ו-`npm audit` בתחנת העבודה, `git grep` לאישורים ולכתובות מעבדה, סקירת כל נתיב שה-add-on כותב אליו. הרצה חוזרת לפני כל שחרור פיילוט (`python -m pip_audit -r smplwise_vms/backend/requirements.txt`, `npm audit` בתיקיית `frontend/`, ה-grep על עץ המעקב בסעיף 3).

1. מלאי זמן ריצה ורישויים

רכיב	גרסה	רישיון	שימוש	הערות
תמונת בסיס Home Assistant `amd64-base-python:3.12-alpine3.22`	כפי שמקובע ב-Dockerfile	Apache-2.0 (של בסיס add-on HA)	בסיס תמונה	בסיס HA רשמי
fastapi	0.141.1	MIT	API של HTTP	
uvicorn[standard]	0.53.0	BSD-3	שרת ASGI	תוספי `standard`: httptools (MIT), uvloop (MIT/Apache), websockets, watchfiles (MIT)
pydantic	2.13.5	MIT	אימות (validation)	
httpx	0.27.2	BSD-3	קריאות NVR / go2rtc / HA	
websockets	≥13,<16	BSD-3	WebSocket של HA, ממסר go2rtc	
python-multipart	0.0.32	Apache-2.0	העלאות	
pillow	12.3.0	MIT-CMU (HPND)	רינדור תוכנית	
numpy	≥2,<3	BSD-3	סגנון תוכנית / זיהוי חדרים	

רכיב	גרסה	רישיון	שימוש	הערות
cryptography	≥45,<51 (50.0.1 בתחנת העבודה)	Apache-2.0 OR BSD-3	חתימת Ed25519 לחבילת ראיות (0.1.67); חתימת VAPID (ES256) והצפנת RFC 8291 `aes128gcm` ל-Web Push (P3 CR-008 - במקום להוסיף את pywebpush)	נוסף אחרי הביקורת הראשונה
ezdxf	≥1.3,<2 (1.4.4 בתחנת העבודה)	MIT	ייבוא תוכנית DXF (0.1.43)	נוסף אחרי הביקורת הראשונה; Python טהור
tzdata	≥2024.1	Apache-2.0	אזורי זמן	
poppler-utils (Alpine)	distro	GPL-2.0 / GPL-3.0	**כתת-תהליך** (subprocess) `pdftoppm`	לא מקושר (linked) לתוך הקוד שלנו; מופעל לכל עמוד עם timeout
ffmpeg (Alpine)	distro	LGPL-2.1+ / GPL-2.0+ (בניית Alpine מפעילה חלקי GPL)	תפיסות פריים, remux לייצוא **כתת-תהליך**	לא מקושר; שורות פקודה מוסתרות (redacted) ביומנים
jpeg, zlib, libpng (Alpine)	distro	IJG / zlib / libpng	קודקים של Pillow	permissive
lit	^3.3.3	BSD-3	רכיבי UI	תלות ה-frontend היחידה בזמן ריצה
vite, typescript, @playwright/test, @types/node	בלבד dev	MIT / Apache-2.0 / Apache-2.0 / MIT	בנייה ובדיקות	לא נשלח
ה-add-on הישן (legacy) `legacy/hikvision_nvr_v1.5.27`	—	קוד של הבעלים עצמו, אין קובץ רישיון	הפניה לקריאה בלבד	לעולם לא מועתק למוצר; שימוש חוזר רק כמתועד ב-`docs/legacy/REUSE_MATRIX.md`
נכסי עיצוב (`docs/design/moc` `kups-v1.3`, לוחות)	—	סופק על ידי הבעלים	הפניה	ערכת ה-PNG המלאה נשמרת באופן פרטי

שום קוד צד-שלישי מוטמע (vendored) לא מועתק לתוך המוצר. קוד הסגנון, זיהוי החדרים והגיבוי הוא מקורי. אינטגרציית הגשר (`custom_components/smplwise_bridge`) תלויה רק ב-API הליבה של Home Assistant.

2. סריקת פגיעויות

סריקה	תוצאה (16.09.2026, 0.1.21)	תוצאה (22.09.2026, 0.1.81)
`pip-audit -r smplwise_vms/backend/requirements.txt`	לא נמצאו פגיעויות ידועות	לא נמצאו פגיעויות ידועות (11 דרישות כולל cryptography, ezdxf)
`npm audit` (frontend, זמן ריצה + dev)	0 פגיעויות (info/low/moderate/high/criti cal כולם 0)	0 פגיעויות; 7 חבילות dev / 70 prod; תלות זמן הריצה עדיין `lit` בלבד
על עץ המעקב (אישורים, טוקנים, כתובות מעבדה, MACs; מספרים סריאליים, fixture מזויפת) grep (נסרק בנפרד `legacy/`)	אין פגיעות מלבד מחרוזת	0 פגיעות; 0 פגיעות `legacy/`

שתי הסריקות נכנסות לרשימת הבדיקה של השחרור (T036); ממצא בחומרה high ומעלה חוסם שחרור עד שהתלות מתעדכנת או שהחשיפה מתועדת כלא-נגישה.

3. סודות

- סודות לעולם אינם חיים במאגר או במסד הנתונים, למעט חריגה שבקשת שינוי מאושרת מגדירה במפורש, כולל ההגנה והמגבלות שלה. אישורי NVR, אישורי go2rtc וטוקן ה-HA (בפיתוח) מגיעים מאפשרויות ה-add-on / `secrets/lab.env`, המוסתר מגיט יחד עם `private-evidence/` ו-`data/`. הסוד המשותף של הגשר נשמר בטבלת ההגדרות של מסד הנתונים של ה-add-on ומוחרג מגיבויים (`SETTINGS_KEEP` ב-`services/backup.py`).
- חריגה מאושרת (CR-022, החלטת הבעלים 2026-10-04; צד השרת מומש ב-`pilot/nn4-backend`, ייצא בשחרור של CR-022): סיסמת חיבור ה-NVR עוברת מאפשרויות ה-add-on אל `recorder_connections.password_enc`, מוצפנת ב-AES-256-GCM עם קובץ מפתח משלה `<data>/keys/connections.key`; לא הטבלה ולא המפתח נכנסים לגיבוי או לחבילת אבחון של Arx, והסיסמה לעולם אינה מוחזרת ב-API ואינה נכתבת ליומן או לרשומת הביקורת. ההגנה היא מפני דליפה של קובץ המסד או של גיבוי Arx, לא מפני מי שקורא את כל תיקיית הנתונים. היקף, מודל איומים ובדיקות: `docs/changes/CR-022-NVR-CONNECTION-IN-ARX.md` סעיף 3. עד השחרור הזה אפשרויות ה-add-on נשארות המקור.
- סריקת מאגר (`git grep` עבור `token=`, `password=`, תבניות כתובת מעבדה; סריקת ה-pre-commit שבשימוש לולאת קטע העבודה מסרבת ל-commit המכיל כתובות מעבדה או מזהי התקן): אין פגיעות מלבד מחרוזת fixture מזויפת ומובהקת ב-`tests/test_media.py`.
- יומנים: כתובות URL של go2rtc מוסתרות (`services/go2rtc.redact_url`), פלט שגיאת ffmpeg מוסתר לפני שהוא נשמר (`services/thumbnails._redact`), פרטי בריאות נוקבים במחלקות שגיאה ולא בכתובות, ומשגר המפתח (developer launcher) לעולם אינו מדפיס ערכי אפשרות. יומן הגישה של Uvicorn מציג את כתובת הלקוח, שבתוך ה-add-on הוא ה-proxy של ה-Supervisor.
- ה-UI לעולם אינו מקבל אישורים: הדפדפן מדבר רק עם ה-add-on, שממסר בעצמו את איתות ה-go2rtc ותמונות ה-NVR (ADR-005 / ADR-011).

4. נתיבי כתיבה מסוכנים (נסקרו)

נתיב	שומר (Guard)
העלאות תוכנית ← `/data/plans`	סניפת תוכן (PDF/PNG/JPG בלבד, SVG נדחה), 40 עמודים / 20 MB, תמונות נגזרות נכתבות לצד המקור, מקורות בלתי ניתנים לשינוי
גיבויים ← `/data/backups`	שורות `..`; תחת תיקיית הנתונים ומסרב לקטעי `files/…` נכתב לשם זמני ואז משנה שם; שחזור מחלץ רק חברי zip וקבצים בטרנזקציה אחת
ייצוא ← `/data/exports`	תיקיית משימה לכל ייצוא, זמני + שינוי שם, גודל נספר בדוח הבריאות
תמונות אירוע ← `/data/thumbs`	timeout עם ffmpeg, אחד, זמני + שינוי שם, מטמון שלילי worker
התקנת גשר ← `custom_components/smplwise_bridge` של Home Assistant	רק כשמיפוי `homeassistant_config` מוענק, רק אותה תיקייה, מסומן בגרסה, מועתק מחדש בשינוי גרסה; מתועד ב-DOCS.md
זרמי go2rtc	רק שמות עם קידומת `smplwise_` נוצרים, מעודכנים או נמחקים; זרמים זרים מוצגים אך לעולם לא ננגעים
NVR	קריאות ISAPI לקריאה בלבד; אין כתיבות תצורה, אין אתחולים (כלל `nvr.config.write`; AGENTS.md היא הרשאה רגישה שאף תפקיד לא מעניק)

נתיב	שומר (Guard)
ממשק התשתית של התוסף (Supervisor), **חריגה מאושרת** (החלטת בעלים D1 של CR-021; צד השרת של S3 בענף `pilot/CR021-s3`, נכנס עם גרסת S3)	המניפסט מבקש `hassio_role: manager`, שמאפשר עקרונית גיבויים, תוספים אחרים, קריאות host ומאגרי חנות. Arx מגביל את עצמו לדלת יציאה אחת, `services/self_update.py`: רשימת היתר מדויקת של (שיטה, נתיב) (`/jobs/info`, `/store/addons/{slug}/update`, `/store/reload`, `/addons/self/info`, `/addons/self/restart`, `/addons/self/options`, `/core/restart`, `/core/check`, `/core/info`), מפתחות גוף מדויקים, תבנית slug לנתיב התבניתי היחיד, בלי הפניות (redirects), בלי הד או שמירה של טקסט מהתשתית; בדיקת CI נכשלת אם נתיב כתיבה לתשתית מופיע בכל מקום אחר. רק בעלי `system.update` (מנהלי מערכת, לא ניתן להאציל) מפעילים את שתי הפעולות; הרשאה ותיעוד לפני קריאת גוף הבקשה; ריצה פעילה אחת בכל רגע; העדכון יכול להגיע רק לגרסה האחרונה בחנות (לעולם לא גרסה שתוקף בוחר); הפעלה מחדש של התשתית רק אחרי בדיקת תצורה שעברה. סיכון שארי (התקבל ב-D1): תהליך Arx פרוץ יכול להשתמש בתפקיד ישירות - ראו `docs/changes/CR-021-SELF-UPDATE.md` סעיפים 3.2, 11 ו-13. שער שחרור: הגנת ענף + סקירה חובה במאגר החנות (תשובת בעלים 11)

5. ממצאים והמשך טיפול

1. **רישויי poppler / ffmpeg** — רכיבי GPL בשימוש כתהליכים נפרדים, מה ששומר על הקוד של ה-add-on עצמו תחת הרישיון שלו; יש להשאיר זאת כך (בלי linking, בלי אריזה (bundling) של קבצים בינאריים מותאמים).
2. **רישיון קוד legacy** — ל-add-on הישן אין קובץ רישיון; הוא נשאר הפניה לקריאה בלבד תחת `legacy/` ולעולם לא מופץ מחדש עם המוצר.
3. **קצב סריקה** — יש להוסיף את שתי פקודות הביקורת לרשימת הבדיקה של שחרור הפיילוט (T036) ולרשומת הסקירה הטכנית של כל שחרור.
4. **כתובות ביומן הגישה** — קביל בתוך Home Assistant (כתובת proxy); לפריסה עצמאית (standalone) יש להוריד את יומן הגישה ל-WARNING (אפשרי כבר דרך אפשרות `log_level`).

שום ממצא לא חוסם הפצת fixture או build פיילוט.

6. יומן סריקה חוזרת

תאריך	גרסה	pip-audit	npm audit	grep ענף	חדש מאז הסריקה הקודמת
16.09.2026	0.1.21	נקי	0	fixture מזויף בלבד	—
22.09.2026	0.1.81	נקי	0	0	עברו ל-dev נוספו למלאי עם הרישיונות שלהם; כלי ה-DXF (`ezdxf`), `cryptography` (חתימה). סריקת הסודות מסרבת כעת גם למספרים סיריאליים; Playwright 1.63 / Vite 6.4 / TypeScript 5.9 שער ה-pre-commit 0.1.6 וכתובות MAC (אשל לולאת קטע העבודה עושה זאת מאז שער ה-pre-commit). שחרור של 22.09.2026 (0.1.81–0.1.76) commit רץ עם 0 פגיעות בכל commit.

עדיין פתוח מ-T069 שסריקה חוזרת זו אינה מכסה: מדיה בגודל חריג הנדחפת דרך go2rtc (דורש את הממסר), סקירת חשיפת ה-API/RTSP של go2rtc על מארח הבעלים (הבעלים), ושידור חוזר (replay) של טוקן חתום Ingress, שהוא שכבת החתום של Home Assistant ורשום כהחרגה מפורשת (ה-add-on לעולם לא רואה או שומר את הטוקן הזה; חלון ה-replay של ה-HMAC של הגשר עצמו נבדק ב-`tests/test_security.py`).